Zero Exposure: private federated learning for hospitals on IBM LinuxONE

Design document · IBM Z Datathon 2026 · Theme: AI Secured: Innovation Without Exposure · Team Zero Exposure

Four hospitals train one heart-disease model. No hospital shares a single patient record.

1. Problem

Diagnostic AI needs many patients, but hospitals cannot legally pool patient records (HIPAA, GDPR, India's DPDP Act 2023), and trust between institutions is low. A small or regional hospital then trains on a few hundred patients and gets a weaker model than a large hospital. The patients who most need good predictions get the worst ones.

2. Who benefits

1. **Small and regional hospitals**: a model trained on far more patients than they hold, with no record leaving the hospital.
2. **Patients**: better risk predictions, while their records stay where they are.
3. **Privacy and compliance officers**: a measurable privacy budget per hospital and proof that the server never sees one hospital's update.
4. **Research consortia**: multi-hospital studies without a central data lake.
5. **Other regulated institutions** (banks, insurers): the same pattern for data they cannot share.

3. Solution: the model travels, the data stays

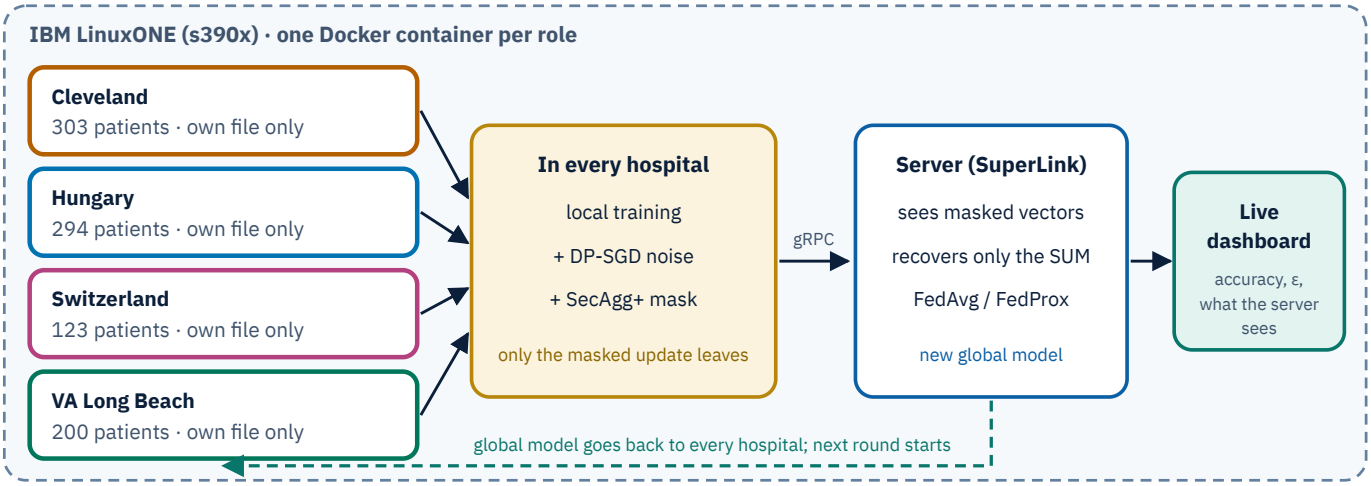
Each hospital trains the shared model on its own data and sends only a protected model update. Three layers protect every update:

1 Federated learning
Flower coordinates the rounds. FedAvg and FedProx combine the hospital updates, including hospitals with very different patients (non-IID data).

2 Differential privacy
DP-SGD (Opacus) limits each patient's influence and adds calibrated noise. Each hospital's privacy budget ε is tracked and shown.

3 Secure aggregation
SecAgg+ masks each update with random numbers that cancel only in the sum. The server can read the total, never one hospital.

4. Architecture on IBM LinuxONE



One SuperLink and four SuperNodes run as separate containers (Flower deployment mode). Each hospital container mounts only its own data file.

5. Data

UCI Heart Disease (public, UCI Machine Learning Repository), collected at four real institutions. We keep each institution as its own federated hospital, so the federation is real, not simulated by splitting one table.

Hospital (federated client)	Patients	Notes
Cleveland Clinic Foundation	303	13 clinical features (age, sex, chest-pain type, resting blood pressure, cholesterol, maximum heart rate, ...) and a heart-disease label. Hospitals differ strongly in size and patient mix (non-IID).
Hungarian Institute of Cardiology, Budapest	294	
University Hospitals Zurich and Basel	123	
VA Medical Center, Long Beach	200	

Each hospital uses a 75 / 25 stratified train / test split of its own patients.

6. One training round

1. The server sends the current global model to the four hospitals.
2. Each hospital trains locally with **DP-SGD**: every patient's gradient is clipped, and Gaussian noise is added. The privacy accountant (RDP) updates that hospital's ε.
3. **SecAgg+** setup: hospitals exchange keys and secret-share their mask seeds, so the masks can be removed even if one hospital drops out.
4. Each hospital uploads only its **masked** update: to the server it is indistinguishable from random numbers.
5. The surviving hospitals help remove the masks from the **sum**. The server averages it (FedAvg / FedProx) into the next global model.

7. Why IBM Z / LinuxONE

- **Real platform, not a slide:** every component runs as a container on LinuxONE (s390x, big-endian). We handle the platform's byte order explicitly so model updates decode correctly on any mix of machines.
- **Consolidation with isolation:** one secure system can host the coordinator and many institution nodes as separate containers, each with its own data.
- **Path to production hardening** (planned, not claimed as built): IBM Secure Execution so even administrators cannot inspect the aggregator; pervasive encryption and Crypto Express for keys and data at rest.

8. How we will measure success

- Accuracy of the federated, private model within a few points of a model trained on all data pooled (the centralized baseline).
- Privacy budget ε reported per hospital, every round.
- Zero raw records leave any hospital container.
- Zero unmasked updates reach the server (checked by inspecting what the server receives).
- The full federation runs end to end on LinuxONE.

9. Threat model and honest limits

- **Threat model:** an honest-but-curious server that follows the protocol but tries to read individual updates.
- SecAgg+ hides one update only inside the sum: with four hospitals, three colluding with the server could reveal the fourth. Differential privacy is still needed for what the released model reveals.
- With small hospitals, strong privacy (small ε) costs accuracy; we report ε openly instead of hiding the trade-off.
- The demo evaluates the global model on held-out test rows; in a real deployment each hospital would evaluate on its own data.

10. Technology

- **Model:** Python, PyTorch (small network for tabular data)
- **Federation:** Flower deployment mode (SuperLink + one SuperNode per hospital)
- **Privacy:** Opacus DP-SGD with RDP accounting; Flower SecAgg+
- **Dashboard:** FastAPI, server-sent events, Chart.js (accuracy, ε per hospital, the masked vector the server receives)
- **Platform:** Docker containers on IBM LinuxONE (s390x)